

Universidad Nacional Autonoma de Mexico



Facultad de Ingenieria

Alumno:

Lara Hernandez Angel Husiel - 320060829

Seguridad informatica basica

Semestre: 2027-1

Practica 7

Lateral Movement

Fecha de Entrega:

31 de Octubre del 2026

Indice

1 Desarrollo **1**
1.1 Revision de la direccion IP y conectividad con webserver 1
1.2 Conexion por SSH y prueba de comunicacion con codeserver 2
1.3 Creacion del tunel SSH con un puerto local 3
1.4 Comprobacion del puerto local con netcat 4
1.5 Instalacion y ejecucion de Remmina 5
1.6 Configuracion del perfil y conexion con codeserver 6

2 Actividades **9**
2.1 Actividad 1: Comando SSH para utilizar el puerto local 3389 9
2.2 Actividad 2: Credenciales validas de codeserver 9
2.3 Actividad 3: Cuenta que permite la conexion remota 10
2.4 Actividad 4: Sistema operativo de codeserver 10
2.5 Actividad 5: Contenido de la etiqueta title 11
2.6 Actividad 6: Ruta absoluta de index.html 11
2.7 Actividad 7: Archivo con el codigo fuente del chatbot 12
2.8 Actividad 8: Hash SHA256 del codigo fuente 13

Referencias **14**

1. Desarrollo

1.1. Revision de la direccion IP y conectividad con webserver

Primero revisamos la direccion IP de nuestra maquina EvilBox. Para esto, el comando que ponemos es el siguiente:

```
ip a
```

Donde en este caso, la interfaz ens33 tiene la direccion `192.168.177.128/24`, por lo que el segmento que vamos a revisar es `192.168.177.0/24`. Despues de esto, utilizamos nmap con el siguiente comando:

```
sudo nmap -sP 192.168.177.0/24
```

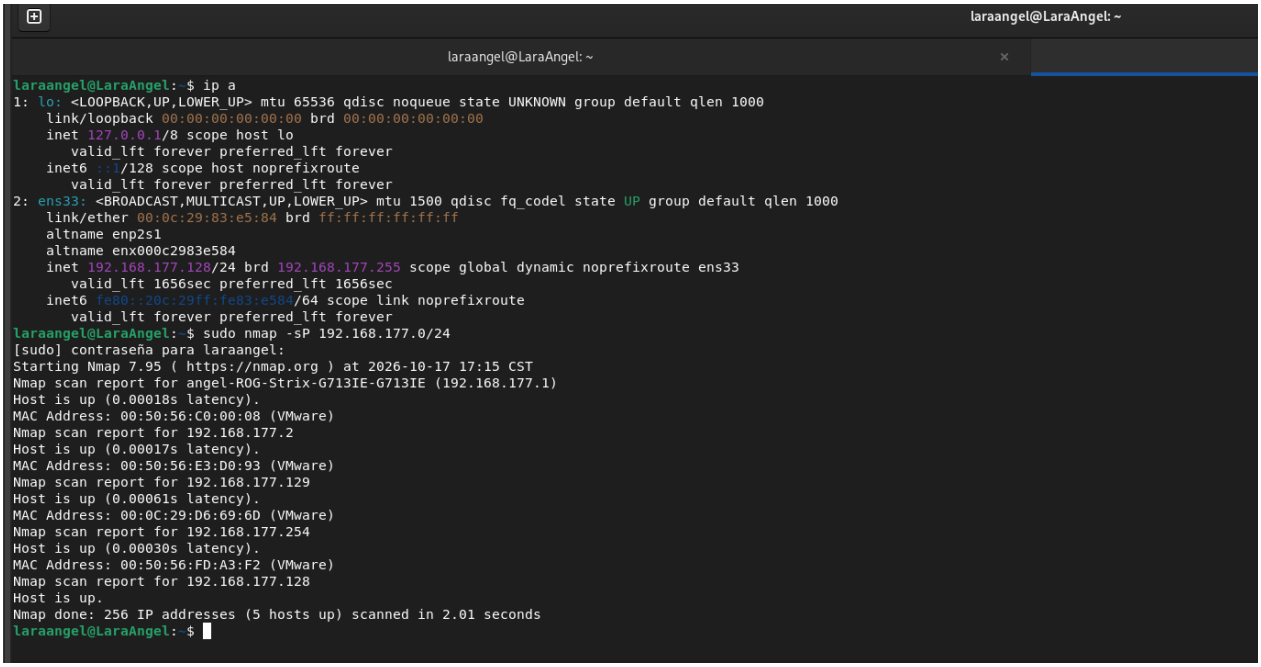


Figura 1: Direccion IP de EvilBox y descubrimiento de los equipos activos.

Lo que hace este comando es identificar los equipos activos del segmento de red. Donde `sudo` permite ejecutarlo con permisos de administracion, `-sP` realiza el descubrimiento de equipos y `/24` corresponde a la mascara `255.255.255.0`. Esta opcion de nmap tambien se conoce como `-sn`.

La salida nos arroja cinco equipos activos, incluyendo `192.168.177.129`, que es la direccion de webserver utilizada en las practicas anteriores. Por lo que, con esta direccion continuamos con la conexion por SSH.

1.2. Conexion por SSH y prueba de comunicacion con codeserver

Para poder conectarnos a webserver, utilizamos las credenciales que se obtuvieron en la practica 3. Recordando que el usuario es webadmin, la contraseña es toronto y el puerto SSH es el 13337, el comando es el siguiente:

```
ssh -p 13337 webadmin@192.168.177.129
```

Donde `-p` indica el puerto del servicio SSH y `webadmin@192.168.177.129` indica el usuario y el equipo al que nos conectamos. Despues en la consola se pone la contraseña, siendo `toronto`.

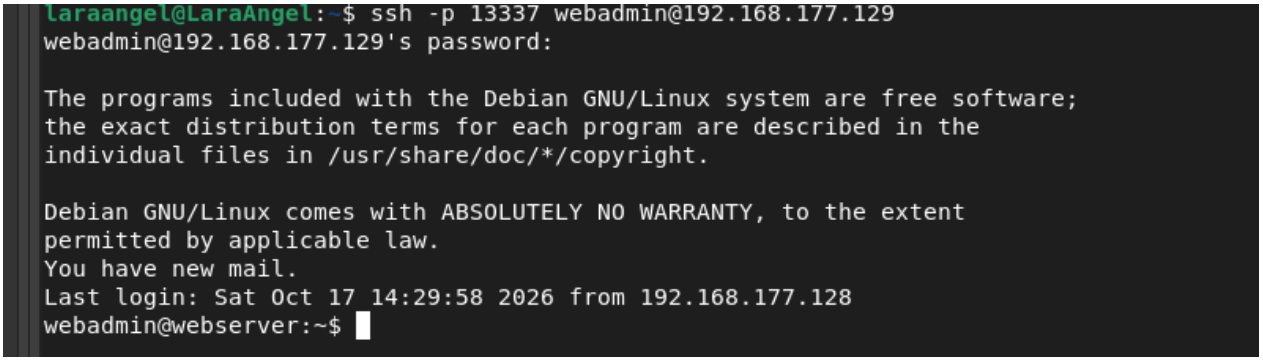


Figura 2: Conexion por SSH desde EvilBox al equipo webserver.

Ahora bien, en la practica 6 se encontro otro equipo en la red interna, siendo su direccion `10.0.0.201`. Para revisar si webserver tiene comunicacion con este equipo, ponemos el siguiente comando dentro de la sesion SSH:

```
ping -c 6 10.0.0.201
```

Lo que hace ping es enviar solicitudes ICMP para comprobar si se reciben respuestas. Donde la bandera `-c 6` limita la prueba a seis paquetes y al final se pone la direccion de codeserver.

```
6 packets transmitted, 6 received, 0% packet loss
```

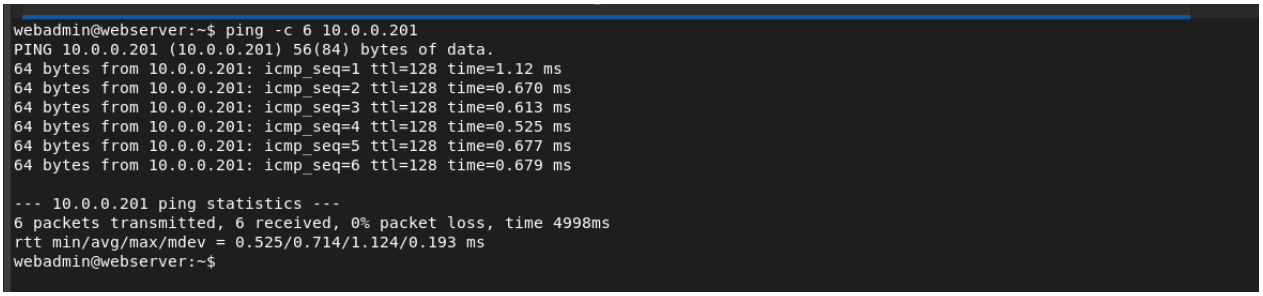


Figura 3: Prueba de conectividad desde webserver hacia codeserver.

Donde en este caso, se enviaron seis paquetes y se recibieron los seis, con una perdida del 0 %. Con esto podemos ver que webserver si tiene comunicacion con codeserver por la red interna.

Despues de esto, hacemos la misma prueba desde otra terminal de EvilBox, utilizando el mismo comando:

```
ping -c 6 10.0.0.201
```

```
6 packets transmitted, 0 received, 100% packet loss
```

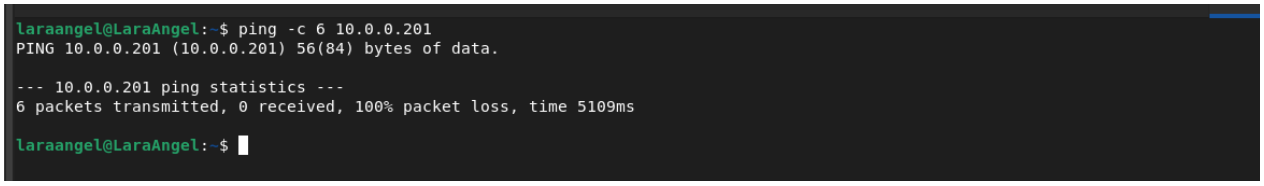


Figura 4: Prueba de conectividad desde EvilBox hacia codeserver.

No obstante, desde EvilBox no se recibio ninguna respuesta y la perdida fue del 100 %. Esto coincide con la configuracion que revisamos en la practica anterior: EvilBox y webserver comparten la red `192.168.177.0/24`, mientras que codeserver se encuentra en la red interna `10.0.0.0/24`.

Ademas de que, webserver tiene una segunda interfaz, eth1, con la direccion `10.0.0.78`, por lo que puede comunicarse con ambos segmentos. Para continuar, vamos a utilizar esa conexion de webserver como paso intermedio hacia codeserver.

1.3. Creacion del tunel SSH con un puerto local

Para poder conectarnos al escritorio remoto de codeserver desde EvilBox, utilizamos un tunel SSH. Para esto, el comando completo es el siguiente:

```
ssh -p 13337 -L 3389:10.0.0.201:3389 webadmin@192.168.177.129
```

Donde la primera parte, `ssh -p 13337`, establece la conexion SSH con webserver. Despues, la bandera `-L` configura el reenvio de un puerto local hacia una direccion y un puerto que se pueden alcanzar desde el servidor SSH.

La parte `3389:10.0.0.201:3389` esta formada por tres valores, los cuales corresponden a lo siguiente:

- **Primer 3389:** puerto local que se habilita en EvilBox.
- **10.0.0.201:** direccion de codeserver en la red interna.
- **Segundo 3389:** puerto del servicio RDP de codeserver.

Por ultimo, `webadmin@192.168.177.129` indica la cuenta que se utiliza para abrir el tunel en webserver. Para esta conexion se escribe la contraseña de webadmin, siendo toronto, y se mantiene abierta la sesion SSH mientras se utiliza el escritorio remoto.

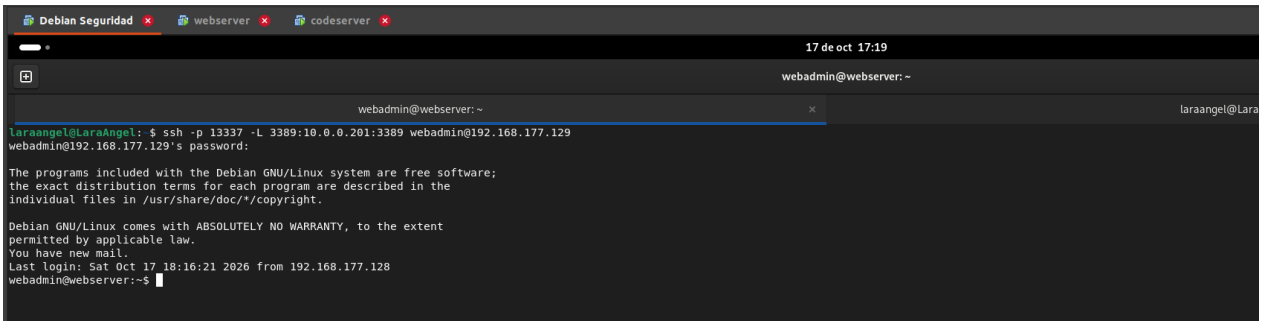


Figura 5: Creacion del tunel SSH hacia el puerto RDP de codeserver.

Con esto, cuando una aplicacion de EvilBox se conecta a `127.0.0.1:3389`, el trafico se envia por la conexion SSH hasta webserver y desde ese equipo se abre la conexion hacia `10.0.0.201:3389`. Por lo que no es necesario que EvilBox tenga acceso directo a toda la red interna.

Ahora bien, el tunel que se creo reenvia conexiones TCP de ese puerto. Esto no agrega una ruta general hacia la red interna ni hace que ping empiece a responder, ya que ping utiliza ICMP.

1.4. Comprobacion del puerto local con netcat

Para revisar que el puerto local quedo disponible, abrimos otra terminal de EvilBox y utilizamos el siguiente comando:

```
nc -zv 127.0.0.1 3389
```

Donde `nc` es la herramienta netcat, `-z` comprueba el puerto sin intercambiar datos de aplicacion y `-v` muestra el resultado de la conexion. La direccion `127.0.0.1` corresponde al propio EvilBox y el puerto 3389 es el que se habilito con la bandera -L.

```
localhost [127.0.0.1] 3389 (ms-wbt-server) open
```

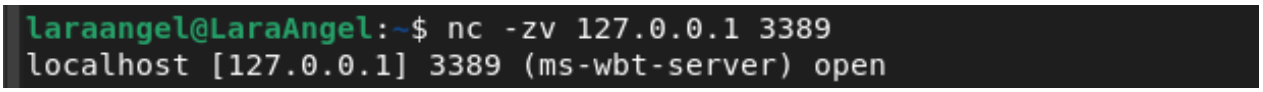


Figura 6: Comprobacion del puerto 3389 local mediante netcat.

Donde en este caso, el resultado open indica que se pudo abrir la conexion TCP al puerto local. Con esto ya se puede utilizar ese puerto desde Remmina; la comprobacion completa del acceso al otro equipo se realiza al iniciar la sesion RDP.

1.5. Instalacion y ejecucion de Remmina

Para establecer la conexion grafica con codeserver, utilizamos Remmina. Para esto, primero se instalaron la herramienta y el complemento para RDP en EvilBox con el siguiente comando:

```
sudo apt update && sudo apt install remmina remmina-plugin-rdp -y
```

Lo que hace `apt update` es actualizar la informacion de los paquetes disponibles. Despues, `apt install` instala Remmina junto con `remmina-plugin-rdp`, que es el complemento necesario para utilizar ese protocolo. Los simbolos `&&` hacen que la instalacion se ejecute si la actualizacion termino correctamente, y `-y` acepta la confirmacion de los paquetes.

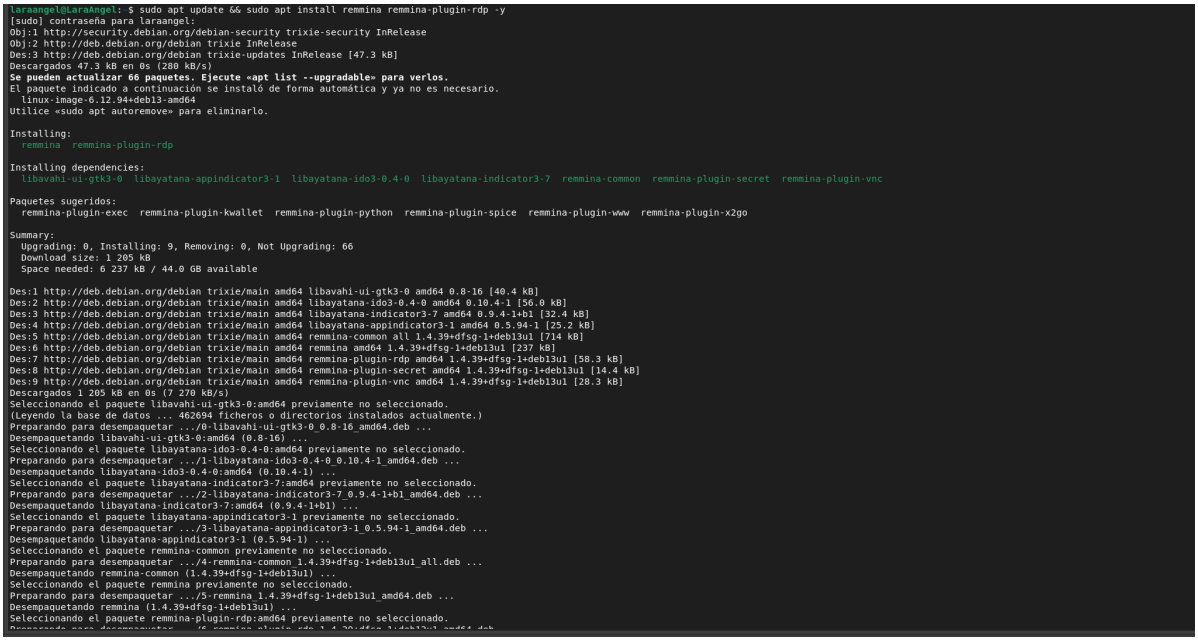


Figura 7: Instalacion de Remmina y del complemento de escritorio remoto.

Despues de esto, para abrir el programa se utiliza el siguiente comando desde la terminal de EvilBox:

```
remmina
```

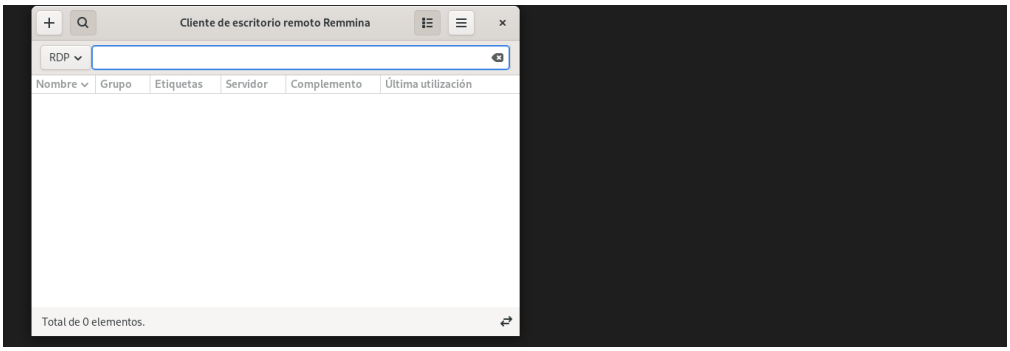


Figura 8: Ejecucion de la herramienta Remmina.

Ahora bien, la conexion se configura hacia `127.0.0.1`, utilizando el protocolo RDP y el puerto local 3389. Esto por que Remmina se conecta al puerto del tunel en EvilBox y SSH se encarga de llevar la conexion hasta codeserver.

1.6. Configuracion del perfil y conexion con codeserver

En el primer intento, Remmina no logro establecer la conexion y devolvio un error relacionado con TLS. Por lo que fue necesario revisar la configuracion del perfil antes de continuar.

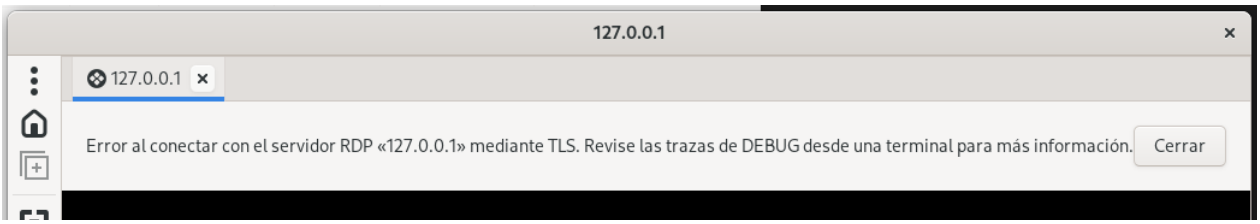


Figura 9: Error de conexion RDP mediante TLS en el primer intento.

Para esto, se creo un perfil llamado Codeserver y se pusieron los datos de la cuenta que se encontro en el archivo passwords.txt de la practica 6. Los valores del perfil son los siguientes:

- **Nombre:** Codeserver.
- **Protocolo:** RDP, protocolo de escritorio remoto.
- **Servidor:** 127.0.0.1, por el puerto local 3389.
- **Usuario:** developer2024.
- **Contraseña:** R0b0tRulz!.
- **Dominio:** se dejo vacio.

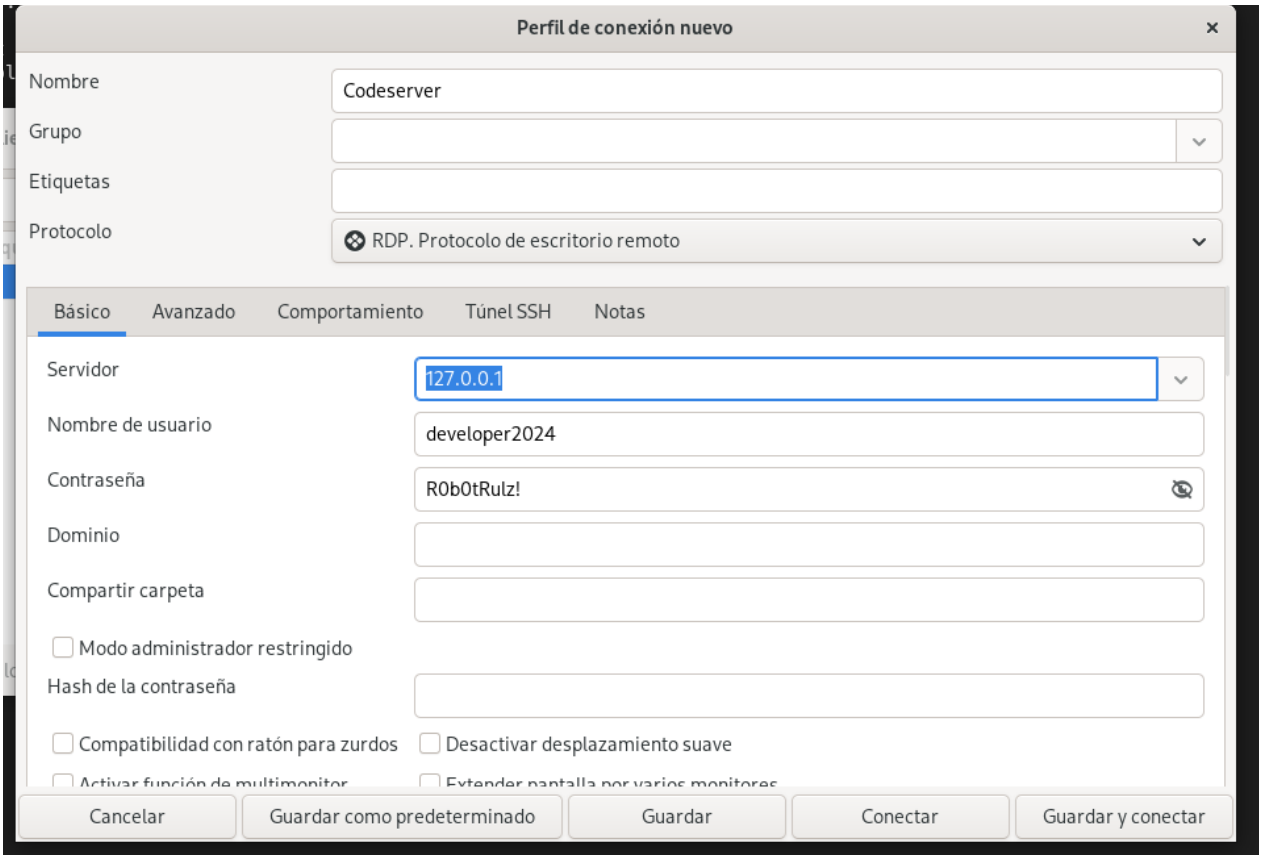


Figura 10: Datos del perfil de conexion RDP para codeserver.

Donde en este caso, el usuario y la contraseña de codeserver son distintos a los de webserver. La cuenta webadmin se utiliza para la conexion SSH, mientras que developer2024 se utiliza para ingresar al escritorio remoto del equipo Windows.

Despues de esto, en la pestaña Avanzado se selecciono **Protocolo de seguridad RDP** en la negociacion del protocolo de seguridad. Ademas de que, la calidad se dejo en **Pobre (mas rapido)** y el nivel de seguridad de TLS quedo en Predeterminados.

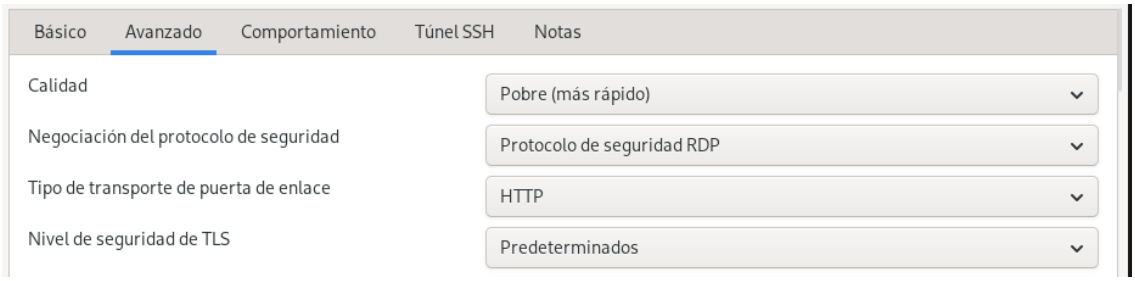


Figura 11: Configuracion avanzada del protocolo de seguridad RDP.

De igual forma, dentro de las opciones avanzadas se marco **Ignorar certificado**. Estos fueron los ajustes utilizados en el perfil de esta conexion para continuar con el acceso al equipo del laboratorio.

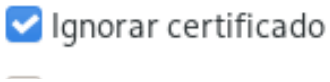


Figura 12: Opcion Ignorar certificado dentro del perfil de Remmina.

Una vez guardados los datos, se volvio a realizar la conexion con el perfil Codeserver y se logro ingresar al escritorio de Windows. Con esto ya tenemos acceso al otro equipo por medio de RDP, utilizando el tunel que pasa por webserver.

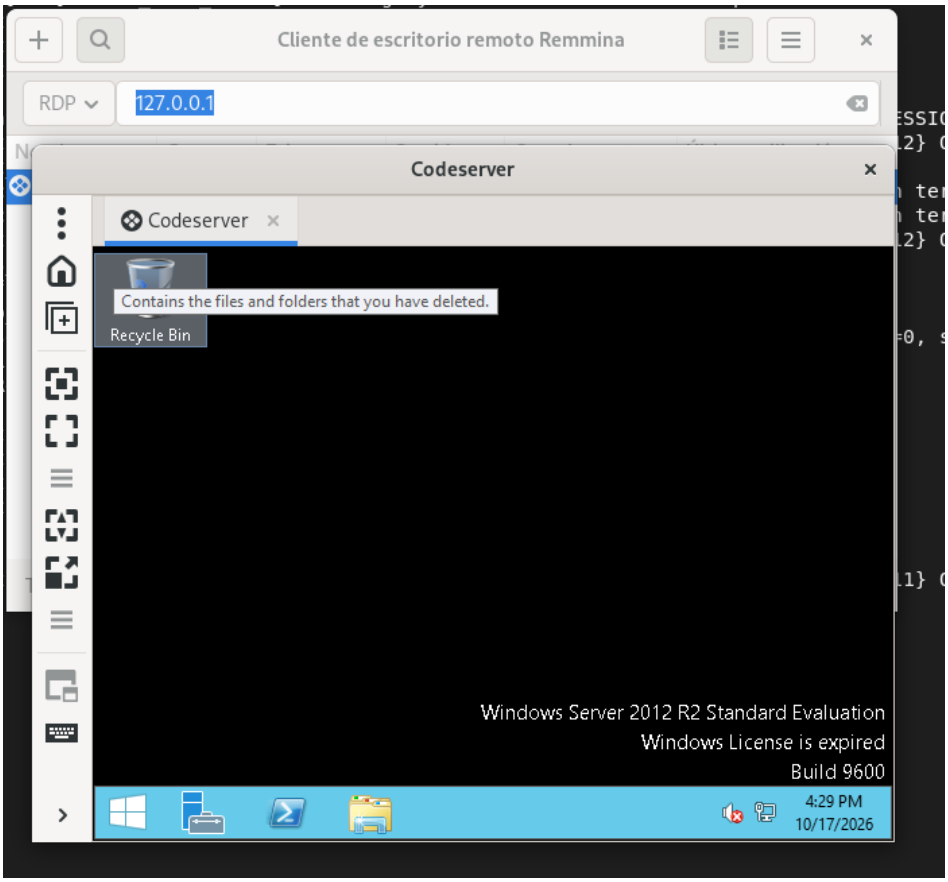


Figura 13: Sesion de escritorio remoto establecida con codeserver.

Por lo que, el movimiento lateral se realiza al utilizar las credenciales encontradas y la comunicacion que tiene webserver con la red interna para entrar a codeserver. A partir de esta sesion se revisa la informacion del sistema y los archivos que se piden en las actividades.

2. Actividades

2.1. Actividad 1: Comando SSH para utilizar el puerto local 3389

¿Cual es el comando de SSH necesario para establecer una conexion desde evilbox hacia codeserver, asumiendo que el puerto local a utilizar es el 3389?

Para esto, utilizamos el comando con el que se creo el tunel durante el desarrollo:

```
ssh -p 13337 -L 3389:10.0.0.201:3389 webadmin@192.168.177.129
```

Donde el puerto local es el primer 3389 de la opcion -L, la direccion de codeserver es `10.0.0.201` y el puerto de destino tambien es el 3389. La conexion SSH se realiza con webadmin hacia webserver, por el puerto 13337.

Despues de crear el tunel, Remmina se conecta a `127.0.0.1:3389` en EvilBox. La contraseña que se solicita al ejecutar SSH es toronto, mientras que las credenciales de Windows se escriben despues en el perfil RDP.

2.2. Actividad 2: Credenciales validas de codeserver

¿Cuales son las credenciales validas para ingresar al equipo codeserver? Utilice el formato usuario:contraseña.

Las credenciales que se utilizaron en Remmina son las que se encontraron dentro del respaldo de ProjectX en la practica 6. En el formato solicitado, la respuesta es la siguiente:

```
developer2024:R0b0tRulz!
```

Donde el usuario es developer2024 y la contraseña es R0b0tRulz!, respetando los ceros, las mayusculas y el signo de admiracion al final. Con esta cuenta se logro ingresar al escritorio remoto de codeserver.



Figura 14: Usuario y contraseña utilizados para la sesion RDP.

2.3. Actividad 3: Cuenta que permite la conexion remota

¿Cual es el nombre de la cuenta de usuario que permite la conexion remota?

La cuenta que permite la conexion remota al equipo codeserver es la siguiente:

```
developer2024
```

Esta es la cuenta que se configuro en el perfil de Remmina y con la que se establecio la sesion de Windows. Por otro lado, webadmin corresponde al acceso SSH a webserver, que se utiliza para mantener el tunel.

2.4. Actividad 4: Sistema operativo de codeserver

¿Cual es el sistema operativo instalado en el equipo codeserver?

Para revisar la informacion del sistema, se abrio la consola de comandos dentro de la sesion remota y se utilizo systeminfo. Para mostrar solamente el nombre y la version del sistema, se puede filtrar de la siguiente forma:

```
systeminfo | findstr /B /C:"OS Name" /C:"OS Version"
```

Donde `systeminfo` muestra la informacion del equipo y la tuberia pasa el resultado a `findstr`. La opcion `/B` busca las coincidencias al inicio de la linea y cada `/C` permite buscar una cadena completa.

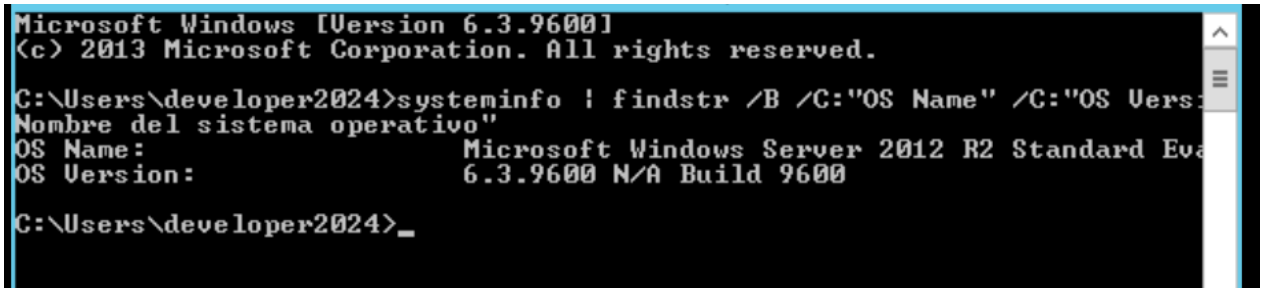


Figura 15: Consulta del nombre y version del sistema operativo.

El sistema operativo instalado es **Microsoft Windows Server 2012 R2 Standard Evaluation**. La version que devuelve el equipo es la siguiente:

```
OS Version: 6.3.9600 N/A Build 9600
```

Con esto podemos ver que se trata de la compilacion 9600 de Windows Server 2012 R2. El nombre de la edicion tambien se identifica dentro del escritorio remoto.

2.5. Actividad 5: Contenido de la etiqueta title

¿Cual es el contenido de la etiqueta HTML title de la pagina web alojada en el equipo codeserver?

Para esto, primero se localizo el archivo index.html y despues se reviso el que se encuentra en el directorio del sitio web. Para obtener solamente la linea del titulo, se puede utilizar el siguiente comando:

```
type "C:\inetpub\wwwroot\index.html" | findstr /i "title"
```

Lo que hace `type` es mostrar el contenido del archivo, mientras que `findstr /i` busca la cadena title sin distinguir entre mayusculas y minusculas. El resultado obtenido es el siguiente:

```
<title>Chatbot</title>
```

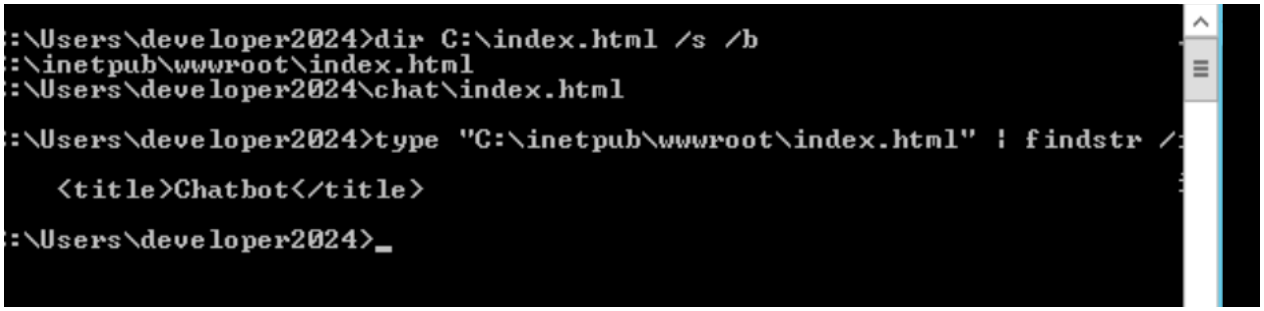


Figura 16: Revision de la etiqueta title del archivo index.html.

Por lo que, el contenido de la etiqueta title es **Chatbot**, con la C mayuscula. Las etiquetas de apertura y cierre son parte del HTML, mientras que Chatbot es el texto que contienen.

2.6. Actividad 6: Ruta absoluta de index.html

¿Cual es la ruta absoluta del archivo index.html ubicado en el equipo codeserver?

Para encontrar el archivo se utilizo el comando dir con una busqueda dentro de la unidad C. El comando es el siguiente:

```
dir C:\index.html /s /b
```

Donde `/s` permite revisar tambien los subdirectorios y `/b` muestra las rutas sin agregar el encabezado ni los datos de tamaño y fecha. El resultado nos arroja dos archivos:

```
C:\inetpub\wwwroot\index.html
C:\Users\developer2024\chat\index.html
```

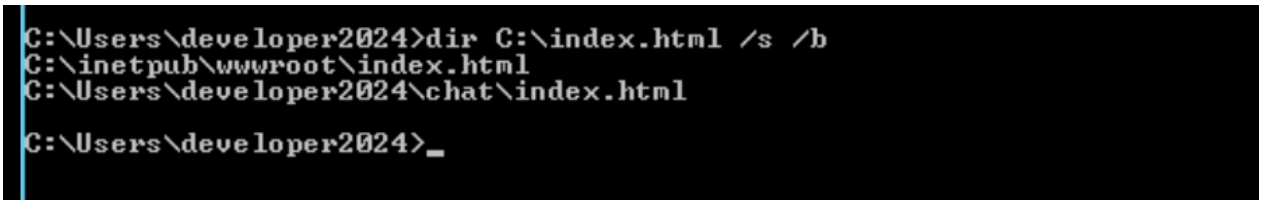


Figura 17: Busqueda de index.html dentro de la unidad C.

Donde en este caso, para la pagina web se toma la primera ruta, que corresponde al archivo index.html dentro del directorio wwwroot. La otra ruta corresponde a una copia dentro del directorio chat del usuario developer2024.

2.7. Actividad 7: Archivo con el codigo fuente del chatbot

¿Cual es el nombre del archivo que tiene el codigo fuente del chatbot?

Para responder esta actividad se revisaron los archivos del directorio del sitio web y del directorio chat del usuario. Los comandos son los siguientes:

```
dir C:\inetpub\wwwroot\ /b
dir C:\Users\developer2024\chat\ /b
```

Donde en este caso, el directorio wwwroot contiene los siguientes archivos:

```
bot.py
configuracion.ini
index.html
script.js
styles.css
```

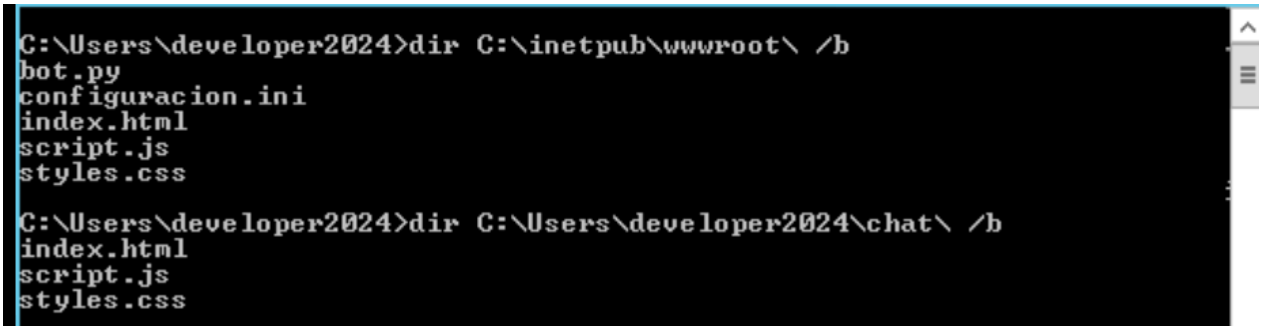


Figura 18: Archivos del sitio web y del directorio chat.

Por otro lado, dentro de chat aparecen index.html, script.js y styles.css. El archivo identificado como codigo fuente del chatbot es **bot.py**, ubicado en el directorio wwwroot del servidor web. La extension py corresponde a un archivo de Python.

2.8. Actividad 8: Hash SHA256 del codigo fuente

¿Cual es el hash SHA256 del archivo que tiene el codigo fuente del chatbot?

Para obtener el hash del archivo bot.py se utilizo certutil dentro de la consola de Windows. El comando completo es el siguiente:

```
certutil -hashfile "C:\inetpub\wwwroot\bot.py" SHA256
```

Donde `-hashfile` indica que se va a calcular el hash de un archivo, despues se pone la ruta completa de bot.py y al final se especifica el algoritmo SHA256. La salida muestra el hash separado en pares de caracteres, de la siguiente forma:

```
b4 94 a0 d1 fc 37 d7 16 ab 00 69 4e da 6f 35 95
f6 4f e7 b9 75 91 a8 b5 f1 3e 9f 90 a7 22 36 49
```

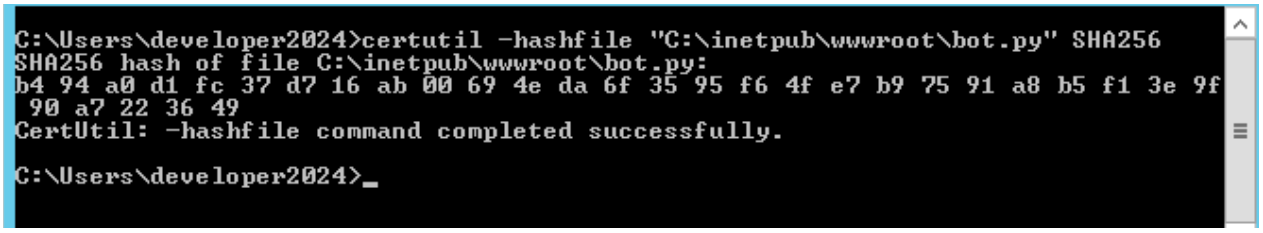


Figura 19: Calculo del hash SHA256 del archivo bot.py.

Ahora bien, para escribir el resultado como una sola cadena, se quitan los espacios entre los pares, conservando los mismos valores. Por lo que el hash SHA256 es el siguiente:

```
b494a0d1fc37d716ab00694eda6f3595f64fe7b97591a8b5f13e9f90a7223649
```

Este valor corresponde al contenido del archivo bot.py que se reviso en codeserver. Ademas de que, la salida de certutil indica que el comando termino correctamente.

Referencias

Microsoft. (s.f.-a). *certutil*. Consultado el 17 de octubre de 2026, desde https://learn.microsoft.com/en-us/windows-server/administration/windows-commands/certutil

Microsoft. (s.f.-b). *dir*. Consultado el 17 de octubre de 2026, desde https://learn.microsoft.com/en-us/windows-server/administration/windows-commands/dir

Microsoft. (s.f.-c). *findstr*. Consultado el 17 de octubre de 2026, desde https://learn.microsoft.com/en-us/windows-server/administration/windows-commands/findstr

OpenBSD. (s.f.). *ssh(1): OpenSSH remote login client*. Consultado el 17 de octubre de 2026, desde https://man.openbsd.org/ssh

Remmina. (s.f.). *How to install Remmina*. Consultado el 17 de octubre de 2026, desde https://remmina.org/how-to-install-remmina/